ALPHAGEN: PRIVACY GATEWAY

МОДУЛЬ БЕЗОПАСНОСТИ ПЕРСОНАЛЬНЫХ ДАННЫХ

Команда Flying cats

Безопасное взаимодействие с LLM.

Контроль. Защита. Гибкость.

Executive summary

Проблема: LLM нельзя отдавать реальные персональные данные.

- Бизнес-системы активно используют LLM, но в запросах утекают ПДН: ФИО, телефоны, email, паспорта, адреса.
- Законодательство и требования ЦБ запрещают передавать такие данные внешним моделям.
- Разные команды решают задачу по-своему: решения несовместимы, дублируются, их тяжело переиспользовать.
- Если демаскирование не реализовано полностью:
ответ модели теряет смысл.
- Безопасность vs удобство: либо запрещаем LLM, либо рискуем утечкой.

Решение: FastAPI-прокси между системой-потребителем и LLM.

Единый endpoint /process — точка входа для всех систем.
Первый запрос с payload_id → маскирование + сохранение соответствия.
Второй запрос с тем же payload_id → демаскирование + возврат оригинала.
Ответ всегда в формате {"result": "..."} — простой контракт, легко интегрировать.
Никаких открытых ПДН в LLM — уходит только токенизированный текст.

> **Ключевой принцип:**
> Данные не покидают защищённый контур в открытом виде. LLM видит токены — клиент получает реальные значения.

Покрытие: все 17 обязательных категорий ПДН.

№	Категория	№	Категория
1	ФИО	10	Адрес
2	Дата рождения	11	Email
3	Место рождения	12	Телефон
4	Паспорт РФ (серия/номер)	13	ИНН
5	Гражданство	14	Номер карты
6	Орган выдачи паспорта	15	CVV
7	Код подразделения	16	PIN
8	Дата выдачи паспорта	17	Имя держателя карты
9	Водительское удостоверение		

Дополнительно: Загранпаспорт, Свидетельство о рождении.

Устойчивость к вариациям:

- Регистр (иванов, ИВАНОВ, Иванов).
- Форматы дат (21.03.1990, 1990-03-21, 03.21.1990, 21 марта 1990 года).
- Даты прописью (двадцать первое марта 1990 года).
- Обфускации (test @ example.org, 1234 5678).
- Разделяющие слова (серия 45 09 номер 123456).

Контекстные ловушки:

- «Поэт Александр Пушкин» — не маскируется.
- «Адрес отделения банка» — не маскируется.
- «Клиент Александр Пушкин, паспорт…» — маскируется.

Архитектура: конвейер обработки запроса

Система-потребитель

Бизнес-приложение, сервис или пользователь

Запрос с данными (возможно, содержащими ПДн)

Запрос (текст, данные)

Ответ (восстановленный, безопасный)

Модуль защиты ПДн

- Авторизация системы
- Выбор политики
- Детекция ПДн
- Разрешение пересечений
- Токенизация / маскирование
- Хранилище соответствий (TTL, SQLite / Vault)
- Демаскирование разрешённых значений

Чувствительные данные не покидают защищённый контур в открытом виде

Безопасный запрос (без ПДн)

Ответ модели (безопасный текст)

LLM / внешняя модель

На вход уходит только безопасный текст

- Без ПДн
- Маскированные данные
- Токены вместо значений

Поддерживающие возможности платформы

API keys / allowlist
Контроль доступа для систем-потребителей

Метрики Prometheus
Наблюдаемость и мониторинг

JSON-логи
Аудит, отладка и трассировка запросов

Local-echo режим для демо
Локальный ответ без обращения к внешней модели

Конфиденциальные данные под контролем

Надёжность и наблюдаемость: Что происходит под нагрузкой

1. JSON-логи этапов обработки: `detection, tokenization, provider, output_guard, restoration`
2. Request ID для трассировки каждого запроса.
3. Метрики Prometheus:
   `privacy_http_requests_total` — запросы.
   `privacy_operation_seconds` — latency.
   `privacy_entities_total` — найденные типы ПДН.
4. 429 с Retry-After — корректная деградация под нагрузкой.
5. Аудит без ПДН — в логах нет реальных значений.

Безопасность:

- Соответствия зашифрованы, живут ограниченное время.
- Нет утечек ПДН в логи и метрики.
- Output_guard блокирует новые ПДН в ответе LLM.

Наши дополнения: Гибкость, контроль доступа

Зашифрованное TTL-хранилище
соответствия живут ограниченное время.

SQLite-WAL для нескольких workers
масштабируемость.

Режим необратимого скрытия
для систем без права восстановления.

Политики под разные системы
support-demo (с восстановлением),
analytics-demo (без).

Повторное использование токена внутри одного сообщения
стабильность.

Комбинационные правила
PIN+ карта → маскируем,
PIN отдельно → не маскируем.

Allowlist по API-ключам
только авторизованные системы.

Receipt с типами найденных данных
прозрачность для клиента.

Добавление новых типов через конфиг
без правки ядра.

Главные преимущества

Главный плюс — данные не уходят в LLM в открытом виде, при этом сохраняется возможность точного восстановления.

> Наше решение не просто набор regex, анастраиваемый gateway: разныеполитики, контроль доступа, аудит,метрики, хранение соответствий ирасширяемость.
> Это можно развивать впромышленный модул ь для разных банковских систем.

Компонент	Что даёт
Политики	Разные правила под разные системы
Контроль доступа	API-ключи, allowlist
Аудит	JSON-логи, request ID
Метрики	Prometheus, latency, RPS
Хранение	Шифрование, TTL, SQLite-WAL
Расширяемость	Новые типы через конфиг